ASP.NET Core Security Flow

Comprehensive Security Architecture for Web APIs

1

CLIENT (Frontend / App)

Build Request

- Encrypts via TLS
- Adds Authorization Header: Bearer `<JWT>`
- Adds X-Signature / X-API-KEY if required
- Optionally AES encrypts payload

2

API GATEWAY / FIREWALL

Network Security Layer

- HTTPS terminates here
- IP whitelisting, DDoS protection
- Rate limiting

3 ASP.NET Core Middleware Pipeline

CORS Validation

- Checks Origin headers
- Allows or denies cross-origin requests

API Key Middleware (optional)

- Validates `X-API-KEY` header
- Rejects unauthorized service calls

Rate Limiter Middleware (optional)

- Enforces per-client call thresholds

4 Authentication Middleware

JWT / OAuth Authentication

- Extracts Authorization: Bearer `<token>`
- Verifies signature using secret/public key
- Checks token expiration, audience, issuer
- Rejects if invalid or expired

5 Authorization Middleware

Role/Policy Validation

- Validates `[Authorize]` and `[Policy]` attributes
- Evaluates roles, claims, scopes
- Denies access if not authorized

6 Controller Execution

Payload Decryption (if used)

- Decrypt AES/RSA body

Input Validation

- Validate model state, sanitize inputs
- Prevent injection / XSS

Business Logic Executes

- Reads/writes data securely
- Encrypts sensitive data at rest

7 Response Pipeline

Output Encryption (if required)

- Encrypt response body

Add Security Headers

- Strict-Transport-Security
- X-Content-Type-Options
- X-Frame-Options

Logging & Auditing

- Log auth attempts, token issues, anomalies

Return HTTPS Encrypted Response

8 CLIENT RECEIVES

Client Decrypts Response (if encrypted)

Handles/Displays Secure Result